



Executive summary

AI AGENT + MCP + SKILL SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.15.0

No configured risk patterns detected

The selected static scope completed without a detector match. This is not a security pass. Review the unassessed boundaries and validate the controls below.

0

OPEN FINDINGS

0

COVERAGE GAPS

2

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Selected static scope completed.

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Advisory control outcomes: 1 potential gaps; 1 checks need runtime, human or additional evidence.

No open finding groups. Review accepted exceptions, coverage limits and active controls before drawing a deployment conclusion.

[Record a review decision and rescan](#)

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: d4246648ec0e739efdbd0fc8a03c8670f095828210e5768af2e3e1c7a8cad202



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Metrics and calculation	4
Observed findings and mitigating layers	5
Optional advisory review and evidence	6
Coverage gaps and required validation	8
Control checklist and evidence requirements	9
Scan configuration and scope	10
Deterministic checks and optional review	13
Coverage, misses and validation by area	14
Appendix / Deterministic rule inventory	21
Interactive review workspace	22



Priorities and first actions

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Advisory control outcomes: 1 potential gaps; 1 checks need runtime, human or additional evidence.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		0
Medium		0
Low		0
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 0/0 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 2/2 answered checks. Proposals require verification.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Metrics and calculation

No defensible universal security percentage can be calculated from static patterns or model opinions. Zero findings and 100% answered checks do not mean secure or compliant.

Measure	Result	Interpretation
Open deterministic findings	0 (0 critical/high)	Observed pattern counts. No severity weights or compromise probabilities are assigned.
Partial deterministic mapping reach	100.00% (1/1)	Active selected controls with an active selected mapped rule. Available partial coverage, not a pass rate.
Optional AI answer coverage	100.00% (2/2)	Active selected checks with a model answer, including concerns and unknowns. Review completion, not safety.

Selected scope: 1 rules (1 active); 1 controls (1 active); 2 active acceptance checks. 0 recorded coverage gaps.

Exact formulas

$100 \times \text{active selected controls with at least one active selected mapped rule} / \text{active selected controls}$. This describes partial rule availability, not completed tests, passes, or control effectiveness.

$100 \times \text{unique active selected acceptance checks with a received, valid model answer} / \text{active selected acceptance checks}$. An answer can be a concern or an explicit unknown. Disabled AI has zero answered checks; an empty denominator is not applicable (null), never 100%.

Advisory AI outcomes

Check outcome	Count
supported_by_code	0
potential_gap	1
needs_runtime_validation	0
needs_human_review	0
insufficient_evidence	1
not_applicable_proposed	0
not_reviewed	0

Supported by code and proposed non-applicability are advisory interpretations. Runtime/human validation and missing evidence remain unresolved. AI cannot erase findings, lower their severity, change the severity gate, or turn checks into passes.

Justified and disabled rules/checks are excluded from active metric denominators without pass credit. Findings with user decisions or baseline suppressions remain visible outside open-finding counts. Selection narrows the requested scope; it does not establish the excluded system is safe.

The existing CLI gate uses open deterministic findings at or above the configured severity. Scan/review/export errors can make requested work incomplete. Coverage percentages and model opinions never dismiss the gate.



Observed findings and mitigating layers

No selected static pattern was emitted. Review coverage gaps and control evidence before drawing a conclusion.



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

Bounded evidence investigation

Follow-up rounds: 1. Requests served / denied: 1 / 0. Captured files offered: 2. All requests share the configured call and evidence budgets; target tools and code are never executed.

EXEC-05:1 / file-01133ae2e5e076d2cc2525ac:13-41 / counterevidence / served

Reason: tool_forward passes caller-controlled user_url to dispatch with lane 1. Inspect _admit to determine what destination and scheme constraints apply before requests.post, and whether the constant-destination lane has different enforcement.

Counterevidence: Seek lane-specific rejection, destination allowlists, URL parsing, IP/DNS validation, or other constraints protecting lane 1. Redirect following is already explicitly disabled at the visible request call.

EXEC-05 / Advisory check review: reviewed

Check 1 / potential_gap

The visible tool_forward entry point passes caller-selected user_url to dispatch with lane 1. The predicate accepts lane 1 regardless of destination, so its constant-destination comparison does not constrain this entry point before requests.post. Disabling redirects provides a concrete barrier against redirect-based destination changes. Application-level scheme restrictions and connection-time IP/DNS enforcement are not established by the supplied flow. This is an explicitly labeled inert fixture; deployment, external egress restrictions, and exploitability remain unverified.

Risk hypothesis: A caller could supply an internal or metadata destination through user_url; lane 1 satisfies _admit without checking that URL, allowing it to reach requests.post if downstream network controls permit.

Trust boundary: tool_forward receives caller-selected URL and content, dispatch applies _admit, and requests.post performs the outbound operation. The visible predicate does not enforce a destination restriction for lane 1.

Counterevidence considered: The rejection branch was inspected, but its predicate admits lane 1 unconditionally. The sibling fixed_forward uses a constant destination and lane 0, which does not constrain tool_forward. allow_redirects=False blocks automatic redirect following. Fixture labeling provides an alternative explanation for the intentionally permissive code.

Conclusion limits: The static flow supports an advisory concern, not a confirmed vulnerability. Actual tool registration, upstream validation, transport behavior, DNS resolution, deployment reachability, and external egress barriers are unresolved.

Model supplied this advisory interpretation.

Evidence src-ea8f5ad7a1e9b55c0a223d85 / agent.py:5-7

Quoted excerpt: def tool_forward(user_url, user_content):
"""Forward a caller-selected record through the delivery boundary."""
return dispatch(1, user_url, user_content)

Evidence src-e5731df412d29009bbf4b319 / delivery.py:17-18

Quoted excerpt: def _admit(a, b):
return a == 1 or b == "https://approved.invalid"

Evidence src-6a02164f7498f198ded37c26 / delivery.py:37-41

Quoted excerpt: def dispatch(lane, addr, record):
if not _admit(lane, addr):
raise ValueError("Unsupported destination")
return requests.post(addr, json={"record": record}, timeout=5,
allow_redirects=False)

Verification still required: Confirm whether this fixture represents a deployed agent tool and identify caller authorization, URL constraints, and outbound proxy or firewall enforcement.

Verification still required: In an authorized isolated environment, verify that rejected destinations produce no connection and that DNS changes cannot move an admitted request to a prohibited address.

Verification still required: Verify that redirects remain disabled throughout the delivery chain, including any caller retries or response handling.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: The relevant boundary is caller-controlled tool input becoming an outbound HTTP request. If this entry point is exposed through an agent or MCP tool, lane 1 currently bypasses the visible destination comparison.

When this applies: Apply changes if this fixture reflects production behavior and callers can influence destinations. First establish the intended destination policy and any independently enforced egress restrictions.



1. Replace unconditional lane-1 admission in `_admit` with destination-policy enforcement for every caller-controlled request, using explicit permitted schemes, hosts, and ports.
2. Use a transport or enforcing egress proxy that validates resolved IPv4 and IPv6 destinations and binds the actual connection to an approved address, preventing DNS changes from bypassing validation.
3. Retain `allow_redirects=False`. If redirects become necessary, enforce the same destination and connection policy independently on every hop.

Verify: Review that no caller-controlled lane can bypass the destination policy.

Verify: Retain isolated integration evidence showing prohibited addresses are blocked at connection time, including DNS changes and redirect responses.

Check 2 / insufficient_evidence

No test definitions, coverage records, or execution results are supplied for the required destination classes and encoding cases. The visible caller-controlled flow identifies what needs testing, and `allow_redirects=False` provides a behavior to validate, but neither establishes that adversarial tests exist or succeed. The fixture label also limits inference about a deployed service.

Risk hypothesis: Destination restrictions could appear effective for ordinary URLs while failing for alternate encodings, IPv6, DNS changes, or redirect handling unless those cases are tested.

Trust boundary: The relevant test boundary spans caller-selected tool input, admission logic, HTTP transport, DNS, and effective outbound network controls.

Counterevidence considered: Redirect following is explicitly disabled, reducing one attack route. The source labels itself an inert fixture, so production tests may exist elsewhere. No supplied test evidence establishes either coverage or its absence.

Conclusion limits: Test completeness and runtime outcomes cannot be assessed from these excerpts. Additional test artifacts and authorized runtime validation are required.

Model supplied this advisory interpretation.

Evidence `src-1c85609fb313cbfd95eb25cd / delivery.py:1-1`

Quoted excerpt: `"""Inert review fixture: network calls below must never be executed."""`

Evidence `src-ea8f5ad7a1e9b55c0a223d85 / agent.py:7-7`

Quoted excerpt: `return dispatch(1, user_url, user_content)`

Evidence `src-6a02164f7498f198ded37c26 / delivery.py:40-41`

Quoted excerpt: `return requests.post(addr, json={"record": record}, timeout=5, allow_redirects=False)`

Verification still required: Obtain existing test definitions and results covering loopback, private and link-local IPv4 and IPv6, cloud metadata, alternate address encodings, and redirect-to-private destinations.

Verification still required: Have an authorized owner validate the actual deployment boundary in an isolated test environment with controlled DNS and destination simulators, recording attempted connections as well as returned errors.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Tests should exercise the caller-controlled `tool_forward` boundary because a fixed-destination sibling does not demonstrate protection for agent-selected URLs.

When this applies: First identify the actual production implementation and existing test suite. Missing submitted tests do not establish that tests are absent; do not execute the supplied inert fixture.

1. If coverage is missing, add a destination-policy matrix covering both address families, metadata destinations, alternate numeric encodings, IPv4-mapped IPv6, and public-to-private redirects.
2. Include controlled DNS changes between validation and connection, and assert that prohibited destinations receive no connection.
3. Exercise the caller-selected entry point and confirm redirect responses do not trigger follow-up requests while `allow_redirects=False` is retained.

Verify: Review test inputs, expected policy decisions, and connection observations for every required case.

Verify: Retain authorized integration results tied to the production transport and egress configuration; mocked policy tests alone do not establish connection-time enforcement.



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Control checklist and evidence requirements

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

[Record review for EXEC-05:1](#)

2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

[Record review for EXEC-05:2](#)

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000
Requested scan ids	EXEC-05
Selected control ids	EXEC-05
Selected rule ids	AI014



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	1
Optional review / Analyst limits / Investigation rounds	2
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	3
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	900.0
Optional review / Cli login	never
Optional review / Cli timeout seconds	300.0
Optional review / Effective transport / Max request bytes	524288
Optional review / Effective transport / Max response bytes	1048576
Optional review / Effective transport / Model	gpt-6-astra
Optional review / Effective transport / Provider	codex_cli
Optional review / Effective transport / Timeout seconds	300.0
Optional review / Effective transport / Token optimizer	headroom
Optional review / Enabled	Yes
Optional review / Findings limit	100
Optional review / Include finding source	No
Optional review / Mode	full
Optional review / Provider	codex_cli
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No



Setting	Configured value
Review inputs / Review config	No
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	02c1a309226db622fe6ab86ae72b3c652e370d2faae3876b7ec64049d8f5e1c5
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.15.0



Deterministic checks and optional review

1 selected deterministic rules (1 active)

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	completed; 0 selected; 0 outside cap
Control review	completed; 1/1 active controls answered
Unanswered acceptance checks	0/2 requested checks
Control requests	2/3 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		1
Controls without rule mapping		0

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks propagate selected registered-tool inputs and same-file arguments/returns, retain aliases and exact literal constraints, and check selected execution/file/network sinks. JavaScript tokens support narrow registerTool callbacks and direct-return named/arrow wrappers. Explicit world-writable chmod modes are checked.

Optional analyst: A model can form a trust-boundary hypothesis, request bounded captured source ranges to inspect callers or guards, seek counterevidence and explain what the supplied code still cannot establish.

Can miss or misclassify: Cross-file flows, unknown decorators/methods, complex JavaScript wrappers, dynamic imports, reflection, generated code and runtime values can hide a risk. Recognized resource/binding failures remain gaps. A dangerous API can be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Skills and malicious-tool indicators

Deterministic: Bounded skill/tool/schema descriptions are checked for instruction hijacking, sensitive-data transfer, covert or approval-bypassing actions. Selected Spanish/French/German overrides and paired authority claims supplement English predicates. Python read-only tool annotations are compared with recognized direct write witnesses.

Optional analyst: A model can review intent, indirect social engineering, skill reference context and tool behavior visible in retrieved evidence, including cases where syntax or supported patterns are inconclusive.

Can miss or misclassify: A pattern is risk evidence, not proof of malicious authorship. Obfuscation, remote references, external packages, omitted context and runtime behavior can evade either layer.

Validate elsewhere: Inspect publisher provenance and the exact installed skill/tool; test consequential actions in an authorized isolated environment and verify effective permissions.



Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional request payload optimization

Request	Requested / actual engine	Outcome	Evidence payload bytes
Finding request	headroom / headroom	optimized	1226 -> 1182 44 bytes saved
Control request 1	headroom / headroom	optimized	5331 -> 5164 167 bytes saved
Control request 2	headroom / headroom	optimized	6931 -> 6714 217 bytes saved

These are measured evidence-JSON bytes, excluding instructions, response schemas and provider wrappers. Token and cost savings were not measured. Evidence-preserving formatting does not validate the model's interpretation.



Optional-review audit details

Recorded field	Recorded value
Analyst / Check status counts / Insufficient evidence	1
Analyst / Check status counts / Potential gap	1
Analyst / Coverage / Attempted controls	1
Analyst / Coverage / Batch size	1
Analyst / Coverage / Call budget	3
Analyst / Coverage / Calls made	2
Analyst / Coverage / Catalog checks	2
Analyst / Coverage / Catalog controls	1
Analyst / Coverage / Disabled checks	0
Analyst / Coverage / Disabled controls	0
Analyst / Coverage / Evidence / Budget exhausted	None
Analyst / Coverage / Evidence / Bytes charged	1243
Analyst / Coverage / Evidence / Bytes read	1243
Analyst / Coverage / Evidence / Candidate rankings dropped	0
Analyst / Coverage / Evidence / Candidate snippets	3
Analyst / Coverage / Evidence / Characters selected	1147
Analyst / Coverage / Evidence / Controls total	1
Analyst / Coverage / Evidence / Controls with evidence	1
Analyst / Coverage / Evidence / Controls without evidence	None
Analyst / Coverage / Evidence / Evidence files	2
Analyst / Coverage / Evidence / Failed read bytes charged	0
Analyst / Coverage / Evidence / File read attempts	2
Analyst / Coverage / Evidence / Files read	2
Analyst / Coverage / Evidence / Files verified	2



Recorded field	Recorded value
Analyst / Coverage / Evidence / Full repository review	No
Analyst / Coverage / Evidence / Limitations	Keyword-selected excerpts are partial context and do not prove implementation, absence, effectiveness, or compliance., Only unchanged manifest files are eligible; scanner exclusions and unsupported files remain outside this review., Credentials and environment files are excluded; other redaction is best-effort and source can contain sensitive data., Read budgets reserve one sentinel byte and conservatively charge failed read attempts, even if failure happened before any source bytes were read., No target code is executed, imported, installed, or contacted; repository instructions cannot change retrieval., Runtime behavior and missing evidence require additional validation; an empty control mapping is not a pass.
Analyst / Coverage / Evidence / Limits / Max bytes	2000000
Analyst / Coverage / Evidence / Limits / Max candidates per control	64
Analyst / Coverage / Evidence / Limits / Max chars	60000
Analyst / Coverage / Evidence / Limits / Max chars per excerpt	2000
Analyst / Coverage / Evidence / Limits / Max excerpts per control	4
Analyst / Coverage / Evidence / Limits / Max file bytes	1000000
Analyst / Coverage / Evidence / Limits / Max files	200
Analyst / Coverage / Evidence / Limits / Max lines per excerpt	12
Analyst / Coverage / Evidence / Limits / Max snippets	240
Analyst / Coverage / Evidence / Manifest files	2
Analyst / Coverage / Evidence / Requested characters selected	324
Analyst / Coverage / Evidence / Scope	bounded_excerpts_from_unchanged_scanner_manifest_files
Analyst / Coverage / Evidence / Selection method	deterministic_control_keywords_and_findings
Analyst / Coverage / Evidence / Skipped files	None
Analyst / Coverage / Evidence / Snippets selected	3
Analyst / Coverage / Excluded checks	0
Analyst / Coverage / Excluded controls	0
Analyst / Coverage / Justified checks	0
Analyst / Coverage / Justified controls	0



Recorded field	Recorded value
Analyst / Coverage / Omitted checks	0
Analyst / Coverage / Reviewed controls	1
Analyst / Coverage / Time budget seconds	900.0
Analyst / Coverage / Total checks	2
Analyst / Coverage / Total controls	1
Analyst / Coverage / Unreviewed control ids	None
Analyst / Coverage / Validated controls	0
Analyst / Enabled	Yes
Analyst / Errors	None
Analyst / Status	completed
Judge / Cli / Arguments	-a, never, exec, --ignore-user-config, --ignore-rules, --ephemeral, --skip-git-repo-check, --sandbox, read-only, --json, --color, never, --disable, shell_tool, --disable, unified_exec, --disable, code_mode, --disable, code_mode_host, --disable, computer_use, --disable, browser_use, --disable, browser_use_external, --disable, browser_use_full_cdp_access, --disable, in_app_browser, --disable, image_generation, --disable, view_image, --disable, artifact, --disable, apps, --disable, plugins, --disable, plugin_sharing, --disable, hooks, --disable, multi_agent, --disable, multi_agent_v2, --disable, skill_search, --disable, workspace_dependencies, --disable, shell_snapshot, --disable, memories, --disable, sleep_tool, --disable, goals, --disable, remote_plugin, --disable, tool_suggest, -c, web_search="disabled", -c, mcp_servers={}, -c, project_doc_max_bytes=0, -c, skills.include_instructions=false, -c, model_reasoning_effort="high", --output-schema, <private temporary directory>/response-schema.json, --model, gpt-6-astra, -
Judge / Cli / Auth mode	cli_managed
Judge / Cli / Cli version	0.154.0
Judge / Cli / Descendant termination	process_group
Judge / Cli / Executable	codex
Judge / Cli / Isolation	CLI capability restrictions; installed executable and administrator policy remain trusted
Judge / Cli / Provider	codex_cli
Judge / Cli / Repository working directory	No
Judge / Cli / Request bytes	3396
Judge / Cli / Request sha256	34133c91d94b969dcd38adb13f8731df659d71525791d5f0e5f127442ff961c0
Judge / Cli / Requested model	gpt-6-astra
Judge / Cli / Response bytes	655



Recorded field	Recorded value
Judge / Cli / Response sha256	6d353fc1bace1429869b402b98a9f73b882e1ce19e367a651058ed41e3c3f739
Judge / Cli / Stage	findings
Judge / Cli / Startup warnings	codex_code_mode_intentionally_disabled
Judge / Cli / Structured output requested	Yes
Judge / Cli / Token budget enforced	No
Judge / Cli / Token optimization / Bytes saved	44
Judge / Cli / Token optimization / Engine	headroom
Judge / Cli / Token optimization / Evidence preserved	Yes
Judge / Cli / Token optimization / Fallback reason	Not configured
Judge / Cli / Token optimization / Headroom version	0.37.0
Judge / Cli / Token optimization / Original payload sha256	1b9076ad8b293db6c5d471143639635a64846fb04dfdbaebd328007cd38ebfde
Judge / Cli / Token optimization / Payload bytes after	1182
Judge / Cli / Token optimization / Payload bytes before	1226
Judge / Cli / Token optimization / Requested	headroom
Judge / Cli / Token optimization / Schema version	1.0
Judge / Cli / Token optimization / Scope	Evidence JSON only; excludes instructions, response schemas and provider wrappers
Judge / Cli / Token optimization / Sent payload sha256	5e5f8bc5a3190e60ae553e35efb64adbace6a99571a99b837de40160f3f57bed
Judge / Cli / Token optimization / Status	optimized
Judge / Cli / Token optimization / Token savings measured	No
Judge / Cli / Tools policy	disabled_for_advisory_review
Judge / Cli / Transport	official_cli
Judge / Enabled	Yes
Judge / Model	gpt-6-astra
Judge / Omitted open findings	0
Judge / Provider	codex_cli



Recorded field	Recorded value
Judge / Selected findings	0
Judge / Source context requested	No
Judge / Source context sent count	0
Judge / Source context skipped	None
Judge / Status	completed



Appendix / Deterministic rule inventory

Only selected rules appear here. User-justified and disabled selections remain recorded in the decision audit and do not earn pass credit.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Acceptance check review

[Back to evidence](#)

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: 3007e9fdbf0be8edf287b4f811e86ad4d50ba21a2ae976acdfcc534f4e915ba1

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: 666459be29ce37a1299ad84dfe6c2a673af2ea842c4a2d3180f014885e0fcc9d

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE